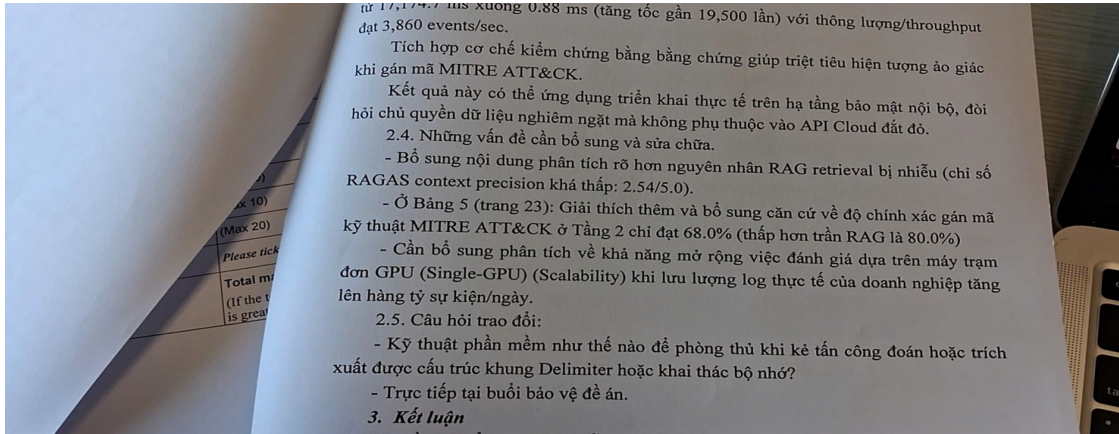


TỔNG HỢP HIỆU CHỈNH LUẬN VĂN & SLIDE BẢO VỆ THẠC SĨ

Học viên: **Nguyễn Đức Bình** — MSHV: **24MSE13183** — Lớp: **MSE23HN**

Đề tài: **Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động sử dụng AI tác tử**

I. Tóm tắt nội dung cần sửa trong report:



1. Giải thích Bảng 5: Khoảng lệch trần RAG (80.0%) và Toàn tuyến Tầng 2 (68.0%)

Bản chất: Do cơ chế Rào chắn neo chứng cứ (Evidence-Anchoring Guardrail) chủ động "khóa miệng" LLM để triệt tiêu ảo giác:

- Khi LLM đưa ra mã tấn công theo trí nhớ tham số nhưng mã đó không có trong 5 tài liệu RAG nạp vào, rào chắn lập tức hủy phán quyết, gán về N/A và chuyển người duyệt (AWAIT_HITL).
- Đây là sự đánh đổi có chủ đích: Em chấp nhận hy sinh 8.8% độ chính xác tự động danh định để đổi lấy 100% quyết định phát ra đều có bằng chứng truy nguyên, ngăn chặn hoàn toàn rủi ro AI ảo giác gây cấu hình sai tường lửa.

2. Phân tích nguyên nhân RAG retrieval bị nhiễu (RAGAS Context Precision: 2.54/5.0)

Bản chất: Do chiến lược "thà kéo thừa còn hơn bỏ sót" và tính không đồng nhất của kho tri thức kép (Dual-RAG):

- Hệ thống ưu tiên tuyệt đối cho Recall (đạt 82.2%) vì trong an ninh mạng, thà kéo thừa tài liệu để LLM lọc còn hơn bỏ lọt đòn tấn công (False Negative).
- Việc nạp gộp cả cẩm nang ứng cứu NIST lẫn kỹ thuật MITRE khiến ngữ cảnh bị loãng: Khi mô hình trọng tài (LLM Judge) chỉ chấm bài toán gán nhãn tấn công, toàn bộ tài liệu hướng dẫn xử lý của NIST bị coi là "nhiều".
- Em nhận diện đây là giới hạn của kiến trúc đơn đồ thị (Monolithic Context) hiện tại và đã nêu rõ ở Chương 5: Hướng phát triển tiếp theo là tách thành Đa tác tử (Multi-Agent) phân vai độc lập giữa pha gán nhãn (chỉ đọc MITRE) và pha xử lý sự cố (đọc NIST).

3. Phân tích khả năng mở rộng khi log tăng lên hàng tỷ sự kiện/ngày (Scalability Analysis)

⇒ Thiết kế phễu lọc hình nón: phần lớn việc nặng và rác đẩy cho CPU tốc độ cao dọn sạch, chỉ chừa lại đúng vài chục sự kiện "tinh hoa" mỗi giây cho GPU và LLM xử lý, thay đổi code đầu vào từ python thành Rust/Go, dùng thuật toán Drain3 nén các log giống nhau hoặc template như nhau thành 1 sự kiện đại diện đỡ mất thời gian lên LLM phân tích (tránh DDoS hoặc bruteforce,...), backend thay bằng vLLM thay vì ollama, ...

Những chỗ đã update trong report:

STT	Nội dung thay đổi	Page number
1	Giải trình Bảng 5 (68% vs 80%)	Trang 24: Nằm ngay bên dưới Table 5
2	Phân tích RAGAS Context Precision 2.54	Trang 26: Nằm dưới Figure 9
3	Phân tích khả năng mở rộng khi log tăng lên hàng tỷ sự kiện/ngày	Trang 28–29: Nằm ở mục mới Section 4.4 (Infrastructure Scalability Analysis), ngay bên dưới Figure 10
4	Nhận diện giới hạn RAGAS Context Precision 2.54 & Đề xuất kiến trúc Multi-Agent	Trang 32–33: Nằm ở đoạn Limitations và Future Work của Chương 5

II. Tóm tắt nội dung cần sửa trong slide:

1. Slide 3: Thực trạng & Nghịch lý LLM

1. "Điểm phán quyết" $\Rightarrow$ "Điểm nghẽn duy nhất" (Bottleneck):

Bản chất: Dùng chuẩn thuật ngữ kỹ thuật hệ thống. Đánh trúng vấn đề cốt lõi của SOC: lưu lượng cảnh báo đổ về hàng triệu sự kiện nhưng bị tắc nghẽn ở khâu phán quyết thủ công của con người.

2. "Tốc độ đường truyền" $\Rightarrow$ "Lưu lượng dòng sự kiện tốc độ cao":

Bản chất: Chuẩn hóa kỹ thuật. LLM không bị chậm do "dây mạng", mà bị nghẽn vì số lượng log đổ về dồn dập vượt quá năng lực suy luận và ngân sách tính toán của mô hình.

2. Slide 4: Nguyên lý vận hành

1. Lược bỏ từ "Air-gapped" $\Rightarrow$ Diễn giải "100% dữ liệu nằm trong hạ tầng nội bộ":

Bản chất: Tránh gây phản biện. "Air-gapped" theo quy chuẩn quốc phòng đòi hỏi phải rút sạch dây mạng vật lý. Thay bằng giải thích dữ liệu không gửi ra dịch vụ đám mây vừa đúng thực tế đề án, vừa an toàn 100%.

3. Slide 5: Bảng so sánh định vị

1. Thêm NIST vào Dual-RAG (MITRE + NIST):

Bản chất: Khớp trọn vẹn kiến trúc kép. MITRE giúp nhận diện đòn tấn công, còn NIST cung cấp quy trình xử lý và ứng cứu sự cố.

2. "Rẻ trước, đắt sau" $\Rightarrow$ "Phân tầng theo chi phí tính toán":

Bản chất: Xóa bỏ văn nói, nâng tầm thành thuật ngữ học thuật hệ thống (Filtration Economics).

3. "Ký liên kết" $\Rightarrow$ "Chuỗi HMAC-SHA256: Ký băm liên kết chuỗi":

Bản chất: Nêu đích danh thuật toán mật mã chuẩn công nghiệp (Hash Chaining), chứng minh tính toàn vẹn và chống chối bỏ cho dữ liệu điều tra số.

4. Slide 6: Kiến trúc Tầng 1 & Tầng 2

1. Tầng 1 ghi rõ: "Lọc dòng tốc độ cao bằng chữ ký tĩnh và học máy nhẹ":

Bản chất: Đúng kiến trúc cốt lõi của đề án (WAF + Welford + LightGBM). Tránh tuyệt đối việc nhận vơ hoặc nhầm lẫn Tầng 1 là SIEM/SOAR.

2. Tầng 2 ghi rõ: "Phân tích ngữ cảnh đòn tấn công mới, mối đe dọa Zero-day":

Bản chất: Khẳng định vai trò "tinh hoa" của Agentic AI: không làm việc vật đại trà, chỉ kích hoạt khi gặp đòn tấn công khó và biến thể mới.

5. Slide 11: Kết luận

1. "100% Air-gapped" $\Rightarrow$ "Môi trường nội bộ":

Bản chất: Đồng bộ với Slide 4, tạo sự nhất quán từ đầu đến cuối slide, loại bỏ hoàn toàn nguy cơ bị Thầy Cô bắt bẻ về định nghĩa phòng thí nghiệm cách ly vật lý.

Những chỗ đã update trong slide:

Vị trí	Câu trước đó	Câu sửa tương ứng
Slide 3	1. Chuyên viên là điểm phán quyết duy nhất. 2. Chậm: suy luận LLM không đáp ứng nổi tốc độ đường truyền.	1. Chuyên viên là điểm nghẽn duy nhất. 2. Chậm: suy luận LLM không đáp ứng nổi lưu lượng dòng sự kiện tốc độ cao.
Slide 4	Vận hành cục bộ (Air-gapped)	Vận hành cục bộ: 100% dữ liệu nằm trong hạ tầng nội bộ, không gửi ra dịch vụ đám mây nào.
Slide 5	1. Dual-RAG + MITRE 2. rê trước, đặt sau 3. ký liên kết từng bản ghi	1. Dual-RAG (MITRE + NIST) 2. Phân tầng theo chi phí tính toán 3. Chuỗi HMAC-SHA256: Ký băm liên kết chuỗi từng bản ghi
Slide 6	1. Xử lý phần lớn lưu lượng. Không gọi LLM. 2. Chỉ kích hoạt khi leo thang. Suy luận LLM, Dual-RAG, ra phán quyết cuối, niêm phong HMAC.	1. Lọc dòng tốc độ cao bằng chữ ký tĩnh và học máy nhẹ. 100% không gọi LLM. 2. Chỉ kích hoạt khi leo thang: Phân tích ngữ cảnh đòn tấn công mới, mối đe dọa Zero-day qua Dual-RAG và LLM.
Slide 11	tất cả trong môi trường 100% Air-gapped.	tất cả trong môi trường nội bộ.